
DevSecAudit

Un audit de sécurité de site web
que le propriétaire peut lire

Rapport de projet

Septembre 2026

22 contrôles de sécurité, 15 outils et sources de données open source, un score de 0 à 100
expliqué en langage clair, le suivi des corrections jusqu'à leur vérification, et des rapports clients
à la marque de l'agence.

Résumé

Les petites entreprises font tourner leur activité sur un site web construit par une agence ou un indépendant, que plus personne ne vérifie ensuite. Les scanners existants sont écrits pour des ingénieurs sécurité : en-têtes bruts, numéros de CVE, aucune priorité et aucune instruction.

DevSecAudit lit un site de l'extérieur, comme le ferait un attaquant, puis traduit ce qu'il trouve en une page qu'un propriétaire non technique peut exploiter, ou remettre à la personne qui s'occupe du site. Le produit combine 22 contrôles reposant sur des outils open source éprouvés (Nuclei, Nikto, nmap, sslyze, dnstwist, Chromium sans interface) et sur des sources de données publiques, un score étalonné de 0 à 100 avec une note de A à F, et un correctif précis pour chaque constat, adapté à la plateforme d'hébergement réellement détectée.

La contribution qui distingue ce travail n'est pas la détection : c'est le refus de présenter une question sans réponse comme une bonne nouvelle. Un contrôle qui n'a pas pu s'exécuter le dit, avec sa raison ; un constat n'est déclaré *corrigé* que lorsqu'un test a réellement ré-examiné la ressource concernée ; et la couverture de chaque scan est annoncée plutôt que sous-entendue. Autour de ce noyau, le produit ajoute ce qui rend un abonnement défendable pour une agence : le suivi des problèmes par site et par client, des correctifs guidés par environnement, un re-test ciblé qui prouve la correction, et un rapport client à la marque de l'agence partageable par un lien qui expire.

L'ensemble est bilingue français et anglais, couvert par 205 tests automatisés, et déployable sur un seul petit serveur avec Docker Compose.

Mots-clés : sécurité des applications web, audit externe, OWASP, Nuclei, analyse passive, SaaS, FastAPI, Next.js.

Table des matières

Résumé	1
1 Introduction	6
1.1 Contexte	6
1.2 Problématique	6
1.3 Objectifs	6
1.4 Organisation du rapport	7
2 Étude de l'existant	8
2.1 Trois familles d'outils	8
2.2 Positionnement retenu	8
3 Analyse et conception	9
3.1 Besoins fonctionnels	9
3.2 Besoins non fonctionnels	9
3.3 Architecture générale	10
3.4 Modèle de données	10
3.5 Cycle de vie d'un scan	11
4 Les 22 contrôles	13
4.1 Contrôles passifs	13
4.2 Contrôles approfondis	14
4.3 Autorisation : ce que le paiement n'achète pas	14
5 Le score	16
5.1 Barème	16
5.2 Étalonnage	16
6 La fiabilité des résultats	17
6.1 Un contrôle en échec ne dit jamais « propre »	17
6.2 « Corrigé » signifie ré-examiné	17

6.3	La couverture est annoncée	17
6.4	L'ordre des observations	18
7	Du constat à la correction vérifiée	19
7.1	Des problèmes qui persistent	19
7.2	Correctifs guidés	19
7.3	Re-test ciblé	19
7.4	Le prompt de correction pour une IA	21
8	Fonctions destinées aux agences	22
8.1	Clients et coéquipiers	22
8.2	Portefeuille	22
8.3	Rapport client et lien de partage	22
9	Surveillance	24
10	Sécurité de la plateforme elle-même	25
10.1	Sortie réseau du scanner	25
10.2	Facturation	25
10.3	Données personnelles	25
11	Licences et sources de données	26
12	Qualité et tests	27
12.1	Tests automatisés	27
12.2	Contrôles statiques et interface	27
12.3	Revue successive	27
13	Déploiement et exploitation	28
14	Modèle économique	29
15	Résultats, limites et perspectives	31
15.1	Ce qui fonctionne de bout en bout	31
15.2	Limites assumées	31
15.3	Perspectives	31
16	Conclusion	33
A	Captures complémentaires	34

Table des figures

3.1	Architecture : l'API sert l'interface et met les scans en file ; les workers exécutent le moteur de contrôles et écrivent les résultats bruts.	10
3.2	Progression en direct : chaque contrôle se coche à mesure qu'il se termine, avec le nombre de constats déjà trouvés.	11
3.3	Le rapport : score, note, répartition par gravité, second avis indépendant de Mozilla Observatory, et mention explicite des contrôles approfondis absents de ce scan.	12
4.1	La liste des contrôles effectués accompagne chaque rapport, avec leur état et le nombre de constats. Un contrôle non applicable ou ignoré est affiché comme tel.	15
6.1	La couverture est affichée dans le rapport : les pages lues, ce qui n'a pas été visité et pourquoi, et le rappel que les pages sans lien entrant et tout ce qui se trouve derrière une connexion sont hors du parcours.	18
7.1	Les problèmes d'un site, avec leur état, et le rappel de la règle : un problème n'est marqué corrigé que lorsqu'un scan ayant exécuté son contrôle en entier ne le trouve plus.	20
7.2	Un correctif guidé : onglets par environnement, prérequis, extrait à copier, retour arrière, et le bouton qui relance le seul contrôle concerné.	20
7.3	Le prompt est prêt à copier, avec des liens d'ouverture directe vers Claude ou ChatGPT, et un aperçu de son contenu.	21
8.1	Le portefeuille clients : chaque site avec sa note, ses problèmes ouverts, ses problèmes graves, ceux en retard, et l'état de sa couverture.	23
8.2	Le rapport client : résumé pour décideur, problèmes ouverts, corrections vérifiées. Le bandeau de tête reçoit le nom et le logo de l'agence lorsqu'ils sont configurés.	23
9.1	Réglages de surveillance par site : contrôle léger quotidien, résumé hebdomadaire, destinataires des alertes et webhook.	24
14.1	La page de tarifs.	30
15.1	L'interface est utilisable sur téléphone : le rapport complet en une colonne.	32
A.1	La page d'accueil.	34
A.2	Les constats, du plus grave au plus bénin, avec le correctif de chacun.	35
A.3	Première page du rapport PDF, au format A4.	36

A.4	Le prompt de correction, inclus dans le PDF.	37
A.5	Le même rapport en anglais : l'interface, les constats, les correctifs, le PDF et les e-mails sont bilingues.	38

Chapitre 1

Introduction

1.1 Contexte

Un site web vitrine ou marchand est aujourd'hui l'outil de travail principal de beaucoup de très petites entreprises. Il est presque toujours construit par un tiers, agence ou indépendant, puis laissé tel quel. Le propriétaire ne dispose ni du vocabulaire ni des outils pour savoir si son site est correctement configuré, et il n'a aucune raison d'ouvrir un rapport rempli de numéros de vulnérabilités.

Dans le même temps, les défauts qui exposent réellement ces sites sont, pour la plupart, simples et visibles de l'extérieur : absence de redirection vers HTTPS, en-têtes de sécurité manquants, certificat expirant, enregistrement DMARC absent qui laisse usurper l'adresse d'expédition, fichier `.env` laissé en ligne, extension WordPress vulnérable, sous-domaine de test oublié.

1.2 Problématique

Le problème n'est donc pas la disponibilité des outils de détection : ils existent, sont open source et sont excellents. Le problème tient en trois points.

1. **La restitution.** Les sorties des outils s'adressent à des spécialistes. Personne ne traduit le constat en action pour la personne qui doit décider.
2. **La confiance.** Un scanner qui rencontre un pare-feu, un quota épuisé ou un délai dépassé rend souvent un résultat vide, impossible à distinguer d'un site sain. Un produit de sécurité qui se trompe dans ce sens est pire qu'inutile : il rassure à tort.
3. **La continuité.** Un audit ponctuel ne vaut presque rien. Ce qui a de la valeur, c'est de suivre un problème jusqu'à sa correction vérifiée, et de pouvoir le montrer.

1.3 Objectifs

- Auditer un site depuis l'extérieur à l'aide d'outils open source reconnus, sans installer quoi que ce soit chez le client.
- Restituer chaque constat en langage clair, avec le correctif exact pour la plateforme réellement utilisée.
- Ne jamais présenter un contrôle en échec comme un contrôle réussi, et annoncer la couverture de chaque scan.
- Suivre chaque constat jusqu'à une correction vérifiée par un re-test ciblé.

- Donner à une agence de quoi gérer plusieurs sites clients et produire un rapport à sa marque.
- Respecter le cadre légal : ne sonder activement un site qu'avec une propriété vérifiée ou une autorisation enregistrée.

1.4 Organisation du rapport

Le chapitre 2 situe le produit parmi les solutions existantes. Le chapitre 3 présente l'architecture et le cycle de vie d'un scan. Le chapitre 4 détaille les 22 contrôles et les outils qui les portent. Le chapitre 5 explique le score. Le chapitre 6 est consacré à la fiabilité des résultats, qui constitue le cœur de la contribution. Les chapitres suivants traitent du suivi des corrections, des fonctions destinées aux agences, de la surveillance, de la sécurité de la plateforme elle-même, des licences, des tests et du déploiement.

Chapitre 2

Étude de l'existant

2.1 Trois familles d'outils

Famille	Prix typique	Limite pour notre cible
Vérificateurs instantanés (Mozilla Observatory, Sucuri Site-Check)	Gratuit	Chacun ne couvre qu'une tranche : les en-têtes, ou TLS, ou le malware. Aucun ne rassemble le tout, aucun n'explique, aucun ne suit dans le temps.
Protection gérée (Sucuri, SiteLock)	230 à 550 \$ par an, ou 20 à 45 \$ par mois et par site	Service différent et complémentaire : pare-feu applicatif et nettoyage d'infection. Ils ne font pas l'audit de posture (usurpation d'e-mail, expiration de domaine, sosies, exposition).
Scanners professionnels (Pentest-Tools, HostedScan, Astra, Intruder)	39 à 190 \$ par mois pour 5 cibles	Les plus proches techniquement. Ils s'adressent à des équipes sécurité : vocabulaire technique, pas de rapport client, pas de suivi de correction destiné à un non-ingénieur.

2.2 Positionnement retenu

DevSecAudit ne cherche pas à détecter davantage que Nuclei ou Nikto : il les exécute. Sa valeur se situe dans la couche au-dessus.

- La traduction en langage clair, avec un correctif adapté à la plateforme détectée.
- L'honnêteté explicite sur ce qui n'a pas pu être vérifié.
- Le suivi d'un constat jusqu'à sa correction vérifiée.
- Le rapport client, à la marque de l'agence, partageable par un lien qui expire.
- Le bilingue français et anglais, qui ouvre les agences francophones.

Le premier acheteur visé n'est donc pas le propriétaire du site mais **l'agence** qui entretient plusieurs sites clients : elle sait appliquer un correctif, elle doit montrer un travail continu, et elle facture déjà une maintenance.

Chapitre 3

Analyse et conception

3.1 Besoins fonctionnels

Réf.	Besoin	Réalisation
F1	Lancer un audit sur un domaine	Formulaire unique, file d'attente, exécution parallèle des contrôles
F2	Suivre l'avancement en direct	Progression par contrôle, avec le nombre de constats déjà trouvés
F3	Comprendre chaque constat	Titre, explication, gravité, correctif, preuve observée
F4	Obtenir le correctif adapté	Correctifs guidés par environnement (Cloudflare, Nginx, Apache, zone DNS)
F5	Exporter le rapport	PDF à la marque de l'espace de travail, en français ou en anglais
F6	Suivre les corrections	Problèmes persistants par site, re-test ciblé, statut vérifié
F7	Gérer plusieurs clients	Clients, coéquipiers, portefeuille trié par urgence
F8	Surveiller en continu	Scan complet hebdomadaire, contrôle léger quotidien, alertes
F9	Partager avec le client	Lien de partage expirant et révocable, sans création de compte
F10	Payer	Offres gratuite, ponctuelle et mensuelle via Whop

3.2 Besoins non fonctionnels

- **Honnêteté.** Aucun contrôle en échec ne doit produire un résultat vide silencieux.
- **Légalité.** Les contrôles actifs exigent une propriété vérifiée ou une autorisation enregistrée, horodatée et conservée.
- **Confinement.** Le scanner ne doit jamais pouvoir atteindre le réseau interne.
- **Bilinguisme.** Interface, rapports, PDF, prompt IA et e-mails en français et en anglais.

- **Montée en charge.** Ajouter de la capacité doit se faire en ajoutant des workers, pas en réécrivant.
- **Coût d'exploitation.** Un seul petit serveur doit suffire au démarrage.

3.3 Architecture générale

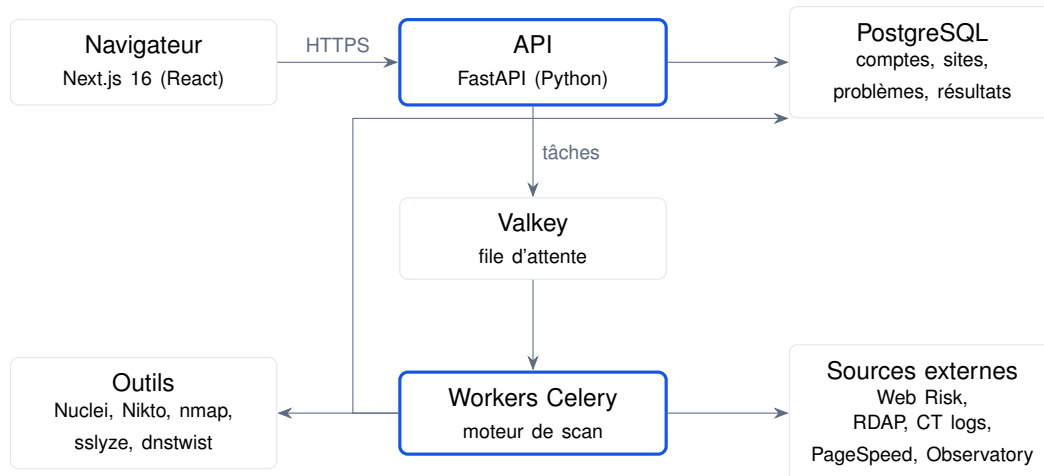


FIGURE 3.1 – Architecture : l'API sert l'interface et met les scans en file ; les workers exécutent le moteur de contrôles et écrivent les résultats bruts.

Les greffons de contrôle forment un unique paquet Python, partagé par l'outil en ligne de commande, l'API et les workers. Ajouter un contrôle consiste à écrire un module et à l'inscrire dans le registre : rien d'autre ne change.

3.4 Modèle de données

Table	Rôle
users	Compte, offre, crédits d'audit, langue, appartenance à un espace de travail, marque des rapports
sites	Domaine, propriété vérifiée, autorisation enregistrée, réglages de surveillance, client associé
scans	Déclencheur (manuel, planifié, quotidien, re-test), sous-ensemble de contrôles, résultat brut en JSON, score, note
issues	Un constat, sur une ressource, suivi dans le temps : statut, première et dernière observation, responsable, notes
audit_windows	Périodes d'audit achetées, conservées séparément pour qu'un nouvel achat ne reverrouille jamais un rapport déjà payé
webhook_events	Chaque événement de paiement déjà appliqué, pour qu'un renvoi n'accorde pas deux fois
clients, invitations, share_links	Espace agence : regroupement par client, invitations à accepter, liens de partage expirants

Le résultat complet de chaque scan est conservé en JSON. Un rapport peut donc être re-noté plus tard, lorsque la formule évolue, sans relancer le scan.

3.5 Cycle de vie d'un scan

1. Le domaine est normalisé et résolu ; une adresse non publique est refusée.
2. Les règles d'offre et d'autorisation décident quels contrôles sont permis.
3. Le scan est mis en file ; un worker le prend et exécute les contrôles en parallèle, chacun avec son propre budget de temps qui démarre au lancement du contrôle.
4. Chaque contrôle terminé est publié immédiatement : l'utilisateur voit la progression réelle.
5. Les constats sont notés, dédoublés, puis synchronisés avec les problèmes suivis du site.
6. Un contrôle ignoré pour une raison temporaire est relancé automatiquement et fusionné.

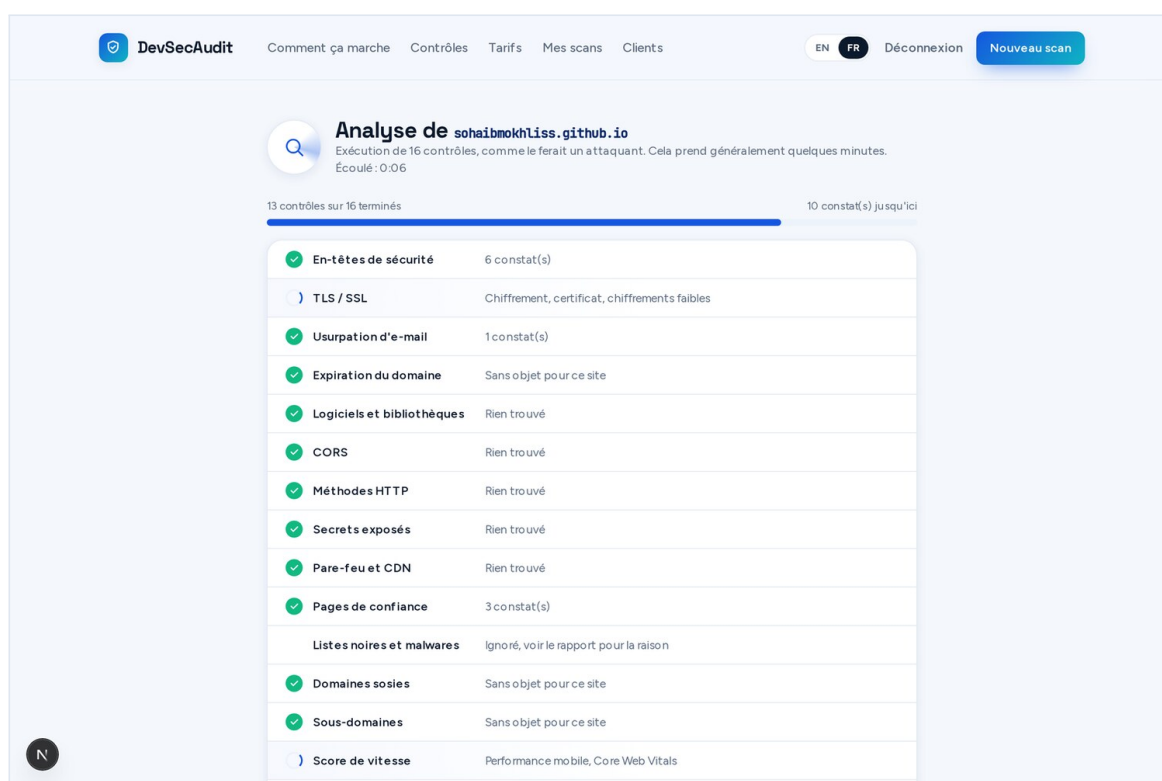


FIGURE 3.2 – Progression en direct : chaque contrôle se coche à mesure qu'il se termine, avec le nombre de constats déjà trouvés.

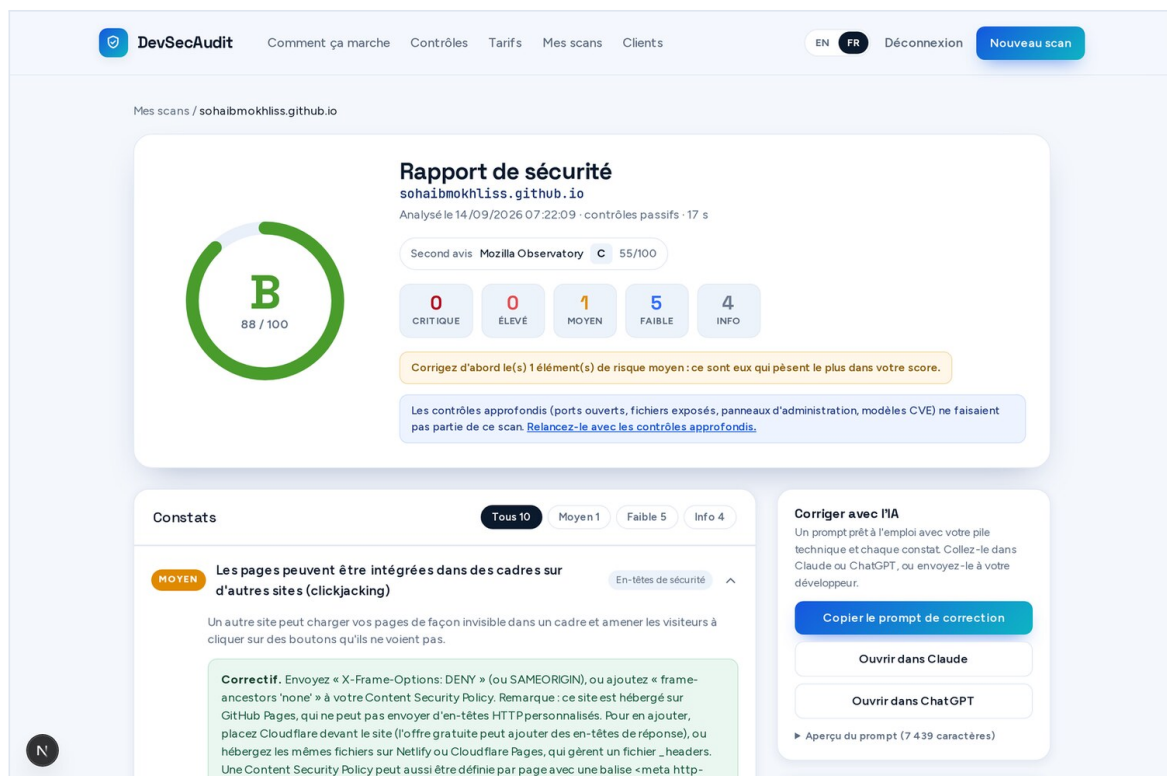


FIGURE 3.3 – Le rapport : score, note, répartition par gravité, second avis indépendant de Mozilla Observatory, et mention explicite des contrôles approfondis absents de ce scan.

Chapitre 4

Les 22 contrôles

4.1 Contrôles passifs

Les contrôles passifs ne lisent que ce qu'un visiteur peut voir : en-têtes, certificats, enregistrements DNS, source des pages, bases publiques. Ils s'exécutent sur n'importe quel site.

Contrôle	Ce qu'il recherche	Outil ou source
En-têtes de sécurité	HSTS, CSP, clickjacking, MIME sniffing, referer policy, redirection HTTPS, attributs des cookies	Client HTTP maison ; second avis Mozilla Observatory
TLS / SSL	Versions du protocole, chiffrements faibles, validité et correspondance du certificat, failles TLS connues	sslyze
Usurpation d'e-mail	SPF, DMARC, DKIM, MX, CAA, DNSSEC, MTA-STS, BIMI	dnspython, résolveurs publics
Expiration du domaine	Compte à rebours, verrou de transfert, registrar	RDAP
Logiciels et bibliothèques	CMS, framework, bibliothèques JavaScript, versions obsolètes ou vulnérables, contenu mixte	Chromium sans interface (Playwright)
Couverture des pages	Parcours borné des pages publiques : formulaires non chiffrés, contenu mixte, en-têtes présents sur l'accueil mais absents ailleurs	Crawler maison, robots.txt respecté
CORS	Origines reflétées, accès inter-origines avec identifiants	Sondes maison
Méthodes HTTP	TRACE et verbes dangereux annoncés	Sondes maison
Secrets exposés	Clés d'API, clés privées, jetons, e-mails dans le code et les scripts	Détection de motifs maison
Pare-feu et CDN	Quel CDN ou WAF est en frontal, scripts tiers	Signatures d'en-têtes et de serveurs de noms
Pages de confiance	Politique de confidentialité, CGU, page contact, bandeau cookies	Crawler maison

Contrôle	Ce qu'il recherche	Outil ou source
Listes noires et malwares	Le domaine est-il signalé pour malware ou hameçonnage	Google Web Risk ; URLhaus, VirusTotal et Safe Browsing intégrés mais désactivés tant qu'ils ne sont pas licenciés
Domaines sosies	Typosquats enregistrés pouvant usurper la marque, avec leurs serveurs de messagerie	dnstwist
Sous-domaines	Environnements de test oubliés, DNS orphelins exposés à un détournement	Journaux de transparence des certificats (crt.sh, Cert Spotter)
Score de vitesse	Performance mobile, Core Web Vitals	Google PageSpeed Insights
Extensions Word-Press	Extensions et thèmes aux vulnérabilités connues	API WPScan (licence requise)

4.2 Contrôles approfondis

Les contrôles approfondis sondent activement le site. Ils ne s'exécutent que sur un site dont la propriété a été vérifiée, ou pour lequel une autorisation écrite a été enregistrée.

Contrôle	Ce qu'il recherche	Outil
Fichiers exposés	.env, .git, sauvegardes, exports de base de données, journaux	Sondes maison
Exposition Word-Press	Énumération d'utilisateurs, XML-RPC, divulgation de version	Sondes maison
Panneaux d'administration	Pages de connexion et phpMyAdmin accessibles depuis internet	Sondes maison
Ports ouverts	Services et bases de données exposés	nmap 7.99, 100 ports les plus courants
CVE connues	Vulnérabilités précises, mauvaises configurations, identifiants par défaut	Nuclei 3.11, environ 13 000 modèles communautaires
Scanner de serveur	Fichiers dangereux, applications d'exemple, logiciel serveur obsolète	Nikto 2.6

4.3 Autorisation : ce que le paiement n'achète pas

Sonder activement un site sans autorisation est, dans la plupart des juridictions, une infraction. Le produit sépare donc strictement deux notions qui sont souvent confondues :

- **L'offre** détermine ce que le client peut acheter : le guide de correction complet, le PDF, la surveillance, le nombre de sites.

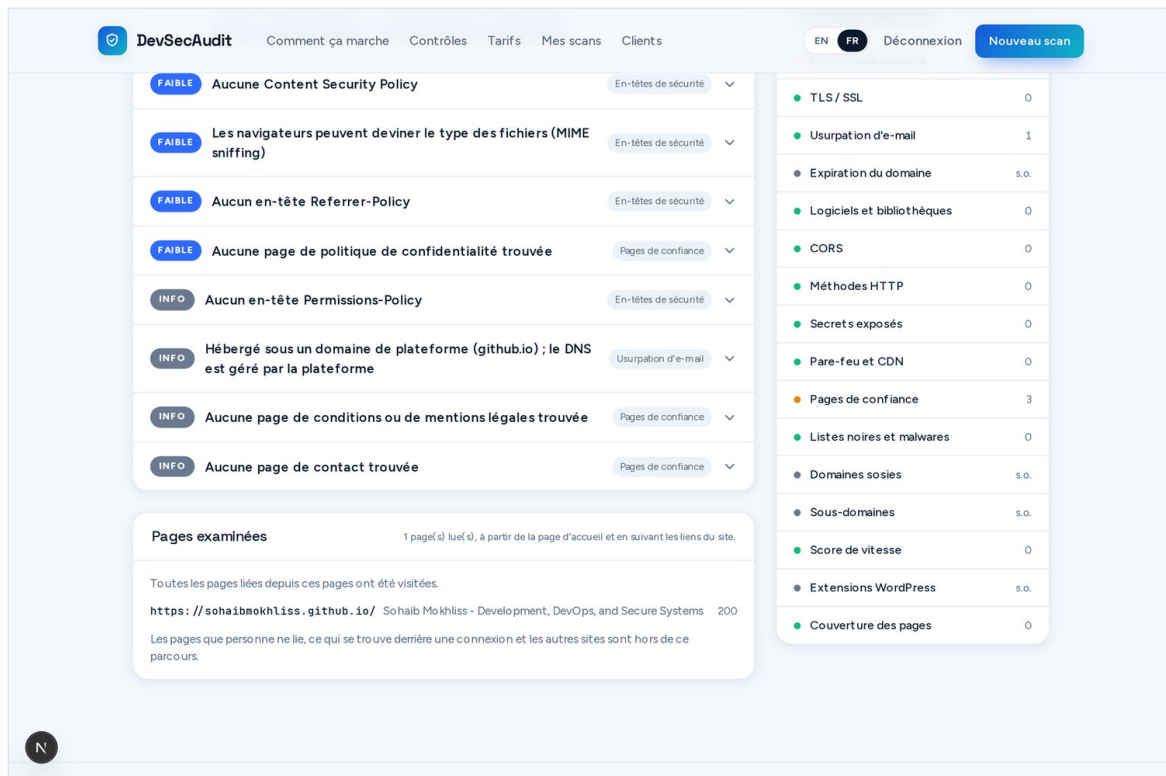


FIGURE 4.1 – La liste des contrôles effectués accompagne chaque rapport, avec leur état et le nombre de constats. Un contrôle non applicable ou ignoré est affiché comme tel.

- **L'autorisation** détermine ce que le scanner a le droit de faire. Elle s'obtient par une preuve technique de propriété (enregistrement DNS TXT ou fichier déposé sur le site) ou, pour une agence qui ne gère pas la zone DNS de son client, par une déclaration écrite enregistrée avec sa date et son adresse IP.

Payer ne donne jamais le droit de sonder. Cette règle est appliquée dans le code, pas seulement écrite dans les conditions d'utilisation.

Chapitre 5

Le score

5.1 Barème

Chaque constat porte une gravité et un poids. Les constats identiques ne comptent qu'une fois, les pénalités à l'intérieur d'un même contrôle décroissent (100 %, puis 50 %, puis 25 %) afin qu'une seule zone faible ne fasse pas sombrer tout le score, et les éléments informatifs sont gratuits.

CRITIQUE 30 **ÉLEVÉ** 15 **MOYEN** 7 **FAIBLE** 2 **INFO** 0

Notes : A $\geq$ 90 B $\geq$ 80 C $\geq$ 65 D $\geq$ 50 F en dessous

Les éléments non strictement sécuritaires, comme la vitesse ou l'absence de page de confidentialité, ont été délibérément placés en gravité faible : ils informent sans dominer.

5.2 Étalonnage

Le barème a été réglé sur des sites réels de façon que la note corresponde à ce qu'un expert dirait. Le tableau suivant présente quatre sites publics analysés le 14 septembre 2026 en contrôles passifs uniquement. La dernière colonne est le point important : le même scan qui produit la note annonce ce qu'il n'a pas pu couvrir.

Site	Score	Note	Constat le plus grave	Non couvert
stripe.com	96	A	FAIBLE un cookie lisible par JavaScript	réputation, vitesse, budget de pages
github.com	96	A	FAIBLE 9 domaines sosies enregistrés, 3 avec serveur de messagerie	réputation, vitesse, budget de pages
bankofamerica.com	86	B	MOYEN un cookie de session sans l'attribut Secure	réputation, vitesse, budget de pages
example.com	62	D	ÉLEVÉ HTTP simple servi sans redirection vers HTTPS	réputation, vitesse

La réputation est désactivée parce que ses sources gratuites ne sont pas licenciées pour un usage commercial (chapitre 11), et la source de performance exige sa propre clé. Un scan exécuté avec ces sources configurées couvre davantage, et le dit.

Chapitre 6

La fiabilité des résultats

Le problème le plus difficile de cette catégorie de produits n'est pas de trouver des problèmes, c'est de refuser de présenter une question sans réponse comme une bonne nouvelle. Trois règles portent ce travail, et toutes les trois sont visibles dans le rapport que reçoit le client.

6.1 Un contrôle en échec ne dit jamais « propre »

Un contrôle qui n'a pas pu s'exécuter le déclare, avec sa raison : quota atteint, clé absente, bloqué par un pare-feu applicatif, délai dépassé, outil en erreur. Le rapport est alors marqué partiel, et le score est accompagné de la liste des contrôles manquants.

Plusieurs cas concrets ont été corrigés au cours du projet, chacun trouvé en simulant la panne plutôt qu'en lisant le code :

- les deux sondes CORS sans réponse produisaient un contrôle « réussi, rien trouvé » ; elles produisent désormais un contrôle ignoré, avec la raison ;
- Nuclei terminant en erreur sans aucun résultat était traité comme un scan vide ; c'est désormais une erreur d'outil ;
- une page de défi anti-robot rendue par le navigateur était analysée comme s'il s'agissait de l'application ; elle est maintenant reconnue comme un blocage, dans la réponse brute comme dans la page rendue.

6.2 « Corrigé » signifie ré-examiné

C'est la règle la plus importante du produit. Un constat n'est déclaré corrigé que lorsque le test concerné a réellement ré-examiné la ressource concernée et ne l'y trouve plus.

Le parcours de pages publie la liste des pages qu'il a pu lire. Si la page qui portait le constat répond 403, disparaît de la navigation du site, est exclue par `robots.txt` ou dépasse simplement le délai, le constat reste *non vérifié* : ni ouvert par erreur, ni corrigé par défaut. Sans cette règle, il suffisait qu'une page devienne inaccessible pour que le produit annonce une correction qui n'a jamais eu lieu.

6.3 La couverture est annoncée

Le rapport indique les pages effectivement lues, et ce qui a été écarté avec la raison : budget de pages, budget de temps, exclusion par `robots.txt`, page illisible, ressource injoignable. Deux scans ne sont

comparés que lorsqu'ils couvrent le même terrain ; sinon le rapport indique que les scores ne sont pas comparables.

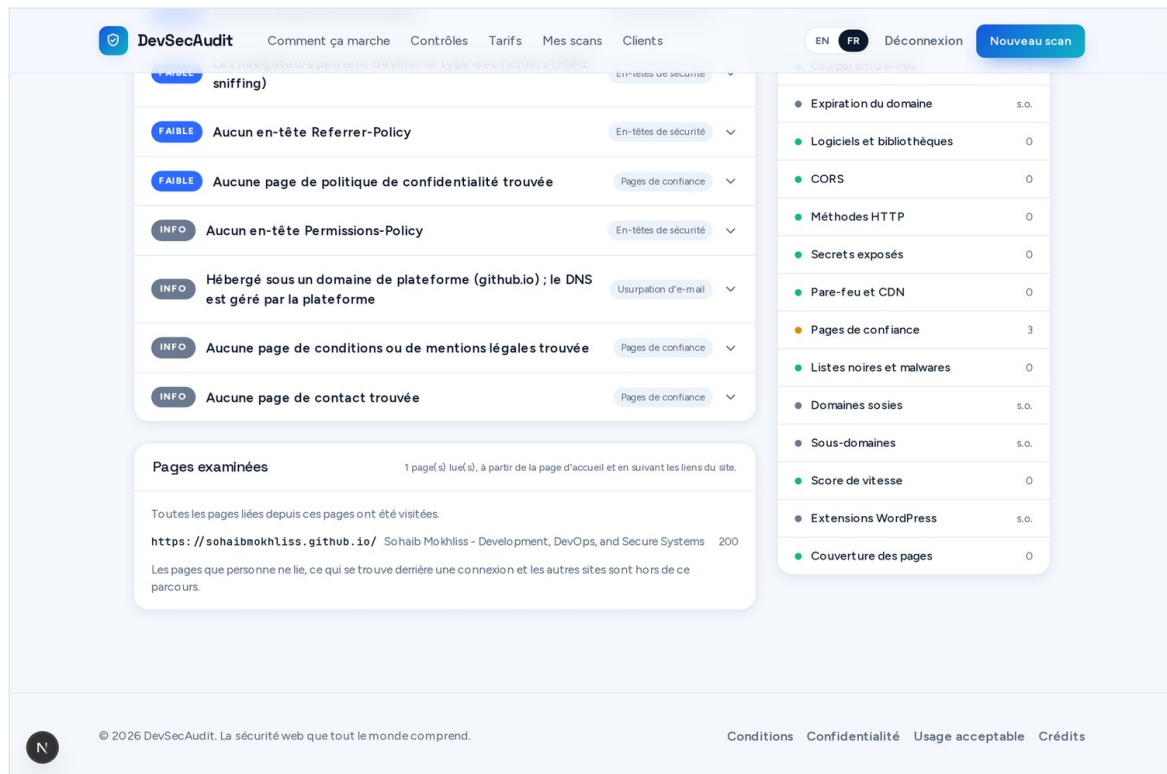


FIGURE 6.1 – La couverture est affichée dans le rapport : les pages lues, ce qui n'a pas été visité et pourquoi, et le rappel que les pages sans lien entrant et tout ce qui se trouve derrière une connexion sont hors du parcours.

6.4 L'ordre des observations

Un scan relancé ou retardé peut se terminer après un scan plus récent. Une observation plus ancienne n'a pas le droit d'écraser une plus récente : un constat rouvert par un résultat périmé, ou un problème ouvert effacé par un ancien résultat, sont des erreurs qui détruisent la confiance. Chaque problème conserve donc la date de la dernière observation qui l'a mis à jour, et un résultat plus ancien est ignoré.

Chapitre 7

Du constat à la correction vérifiée

7.1 Des problèmes qui persistent

Un constat ne disparaît pas quand on ferme le rapport : il devient un *problème* attaché au site, avec son histoire. Chaque problème est identifié par la règle *et* la ressource concernée : deux pages qui échouent au même modèle constituent deux problèmes distincts, et en clore un ne dit rien de l'autre.

État	Signification
Ouvert	Vu lors du dernier scan. Première et dernière observation, responsable et notes conservés.
Non vérifié	Plus visible, mais le test n'a pas pu relire la ressource concernée. Ce n'est pas une correction.
Corrigé	Un scan ayant ré-examiné la même ressource ne le trouve plus, avec un lien vers le rapport qui le prouve.
Risque accepté	Le client sait et l'assume.
Pas un problème ici	Le constat ne s'applique pas à ce site, avec la raison dans les mots du client.

7.2 Correctifs guidés

Quatorze des constats les plus fréquents portent un correctif guidé, écrit pour l'environnement que le client utilise réellement : Cloudflare, Nginx, Apache ou la zone DNS. Chaque guide contient les prérequis, la ligne exacte à coller, la procédure de retour arrière, et ce que la vérification contrôlera.

7.3 Re-test ciblé

Un bouton relance uniquement le contrôle qui porte le constat, au lieu de refaire tout le scan. Si le contrôle s'exécute en entier et ne trouve plus le problème, celui-ci passe à l'état corrigé, avec un lien vers le rapport qui le démontre.

DevSecAudit Comment ça marche Contrôles Tarifs Mes scans Clients EN FR Déconnexion Nouveau scan

Mes scans / sohaibmokhliss.github.io

Problèmes

5 ouvert(s) · 0 non vérifié(s) · 0 corrigé(s)

Re-tester la sélection (0) Re-tester tout ce qui est ouvert (5)

Tous les problèmes de ce site

Tous 6 ouvert 5 pas un problème 1

☐	MOYEN	Les pages peuvent être intégrées dans des cadres sur d'autres sites (clickjacking)	ouvert	En-têtes de sécurité
☐	FAIBLE	Les navigateurs peuvent deviner le type des fichiers (MIME sniffing)	ouvert	En-têtes de sécurité
☐	FAIBLE	HSTS ne couvre pas les sous-domaines	ouvert	En-têtes de sécurité
☐	FAIBLE	Aucune Content Security Policy	ouvert	En-têtes de sécurité
☐	FAIBLE	Aucune page de politique de confidentialité trouvée	ouvert	Pages de confiance
☐	FAIBLE	Aucun en-tête Referrer-Policy	pas un problème	En-têtes de sécurité

Un problème n'est marqué corrigé que lorsqu'un scan ayant exécuté son contrôle en entier ne le trouve plus. Si le contrôle a été ignoré ou interrompu, le problème reste non vérifié.

Surveillance et alertes

Un scan complet chaque semaine, un contrôle léger chaque jour (en-têtes, certificat, DNS, réputation), et une alerte seulement quand quelque chose d'important change.

- ☒ Surveillance active · prochain scan complet le 21/09/2026
- ☒ Contrôle léger quotidien
Exécute chaque jour les contrôles passifs rapides ; alerte seulement sur un nouveau problème grave, un souci de certificat ou de liste noire, ou une vraie baisse de score.
- ☒ E-mail de résumé hebdomadaire
Le résumé du scan complet chaque semaine, même si rien n'a changé.

Destinataires des alertes

FIGURE 7.1 – Les problèmes d'un site, avec leur état, et le rappel de la règle : un problème n'est marqué corrigé que lorsqu'un scan ayant exécuté son contrôle en entier ne le trouve plus.

DevSecAudit Comment ça marche Contrôles Tarifs Mes scans Clients EN FR Déconnexion Nouveau scan

max-age

• En cas de doute, commencez avec un max-age court (ex. 300) pendant une journée, puis augmentez-le.

Cloudflare (devant le site) Nginx Apache (.htaccess)

ÉTAPES

- Dans le tableau de bord Cloudflare, ouvrez SSL/TLS → Edge Certificates → HTTP Strict Transport Security (HSTS).
- Activez HSTS, mettez Max Age à 12 mois et cochez Apply HSTS policy to subdomains (seulement si tous les sous-domaines sont en HTTPS).
- Enregistrez. Cloudflare ajoute l'en-tête ci-dessous à chaque réponse HTTP.

Copier

```
Strict-Transport-Security: max-age=31536000; includeSubDomains
```

SI QUELQUE CHOSE CASSE

- Les navigateurs qui ont déjà vu l'en-tête continuent d'imposer HTTPS jusqu'à la fin du max-age. Pour annuler plus tôt, servez max-age=0 aussi longtemps que le max-age initial, puis retirez l'en-tête.

VÉRIFICATION

Le nouveau test demande la page d'accueil en HTTPS et vérifie l'en-tête, son max-age et includeSubDomains.

Vérifier le correctif Relance uniquement le contrôle de ce problème et le marque corrigé si le problème a disparu.

ce qui a été fait, ce qui bloque

Enregistrer Risque accepté

Pas un problème ici

Tous les problèmes de ce site

Tous 6 ouvert 5 pas un problème 1

☐	FAIBLE	Aucune Content Security Policy	ouvert	En-têtes de sécurité
☐	FAIBLE	Aucune page de politique de confidentialité trouvée	ouvert	Pages de confiance
☐	FAIBLE	Aucun en-tête Referrer-Policy	pas un problème	En-têtes de sécurité

Un problème n'est marqué corrigé que lorsqu'un scan ayant exécuté son contrôle en entier ne le trouve plus. Si le contrôle a été ignoré ou interrompu, le problème reste non vérifié.

Surveillance et alertes

Un scan complet chaque semaine, un contrôle léger chaque jour (en-têtes, certificat, DNS, réputation), et une alerte seulement quand quelque chose d'important change.

- ☒ Surveillance active · prochain scan complet le 21/09/2026
- ☒ Contrôle léger quotidien
Exécute chaque jour les contrôles passifs rapides ; alerte seulement sur un nouveau problème grave, un souci de certificat ou de liste noire, ou une vraie baisse de score.

FIGURE 7.2 – Un correctif guidé : onglets par environnement, prérequis, extrait à copier, retour arrière, et le bouton qui relance le seul contrôle concerné.

7.4 Le prompt de correction pour une IA

Plutôt que d'appeler un modèle de langage à nos frais, le rapport produit un prompt précis : la pile technique détectée, la plateforme d'hébergement, chaque constat avec sa preuve, et la consigne de donner les modifications de configuration exactes pour cette pile. Le client le colle dans l'IA qu'il utilise déjà.

Ce choix a trois conséquences favorables : aucun coût d'IA par scan, aucune invention de faits sur le site puisque tout le contexte est fourni, et des correctifs écrits pour la plateforme réelle — un site hébergé sur GitHub Pages reçoit des instructions Cloudflare ou Netlify, pas des instructions Apache.

The screenshot displays the DevSecAudit web application interface. The top navigation bar includes links for 'Comment ça marche', 'Contrôles', 'Tarifs', 'Mes scans', and 'Clients'. The main content area lists several security findings (constats) with their severity levels and associated details.

- MOYEN** (Medium): 'Les pages peuvent être intégrées dans des cadres sur d'autres sites (clickjacking)'. The description states that another site can load pages invisibly in a frame. The correction (Correctif) involves sending 'X-Frame-Options: DENY' or 'SAMEORIGIN', or adding 'frame-ancestors: none' to the Content Security Policy. It notes that GitHub Pages cannot send custom HTTP headers, suggesting Cloudflare or Netlify as alternatives. The hosting platform is identified as 'GitHub Pages'.
- FAIBLE** (Low): 'HSTS ne couvre pas les sous-domaines'. The description explains that subdomains are not protected by HSTS. The correction involves adding 'includeSubDomains' to the Strict-Transport-Security header. It also notes that GitHub Pages cannot send custom HTTP headers, suggesting Cloudflare or Netlify. The header value is 'max-age=31556952' and the hosting platform is 'GitHub Pages'.
- FAIBLE** (Low): 'Aucune Content Security Policy'.
- FAIBLE** (Low): 'Les navigateurs peuvent deviner le type des fichiers (MIME sniffing)'.

On the right side of the interface, there are several utility buttons and sections:

- A 'Copier le prompt de correction' button.
- Buttons to 'Ouvrir dans Claude' and 'Ouvrir dans ChatGPT'.
- An 'Aperçu du prompt (7 439 caractères)' section.
- A 'Rapport PDF' section with a 'Télécharger le PDF' button.
- A 'Suivre les corrections' section with an 'Ouvrir la liste des problèmes' button.
- A 'Contrôles effectués' table showing 12 out of 16 checks completed.

Contrôle	Statut
En-têtes de sécurité	6
TLS / SSL	0
Usurpation d'e-mail	1
Expiration du domaine	S.O.

FIGURE 7.3 – Le prompt est prêt à copier, avec des liens d'ouverture directe vers Claude ou ChatGPT, et un aperçu de son contenu.

Chapitre 8

Fonctions destinées aux agences

8.1 Clients et coéquipiers

Les sites se regroupent sous un nom de client. Un coéquipier est invité par e-mail et ne rejoint l'espace qu'après avoir accepté depuis son propre compte, via un lien à usage unique qui expire au bout de quatorze jours. L'acceptation est refusée si le compte gère déjà ses propres sites, pour ne jamais faire disparaître le travail de quelqu'un.

8.2 Portefeuille

Le portefeuille trie les clients par urgence : problèmes graves ouverts, corrections en retard de plus de deux semaines, corrections non vérifiées, et trous de couverture comme un site qui n'a jamais reçu de contrôle approfondi.

8.3 Rapport client et lien de partage

Le rapport client porte le nom et le logo de l'agence. Il s'ouvre sur un résumé pour décideur : où en est le site, ce qui a été corrigé et vérifié, ce qui a changé depuis le rapport précédent. Viennent ensuite les problèmes ouverts du plus grave au plus bénin, ceux en attente de vérification, puis les corrections vérifiées.

Le lien de partage est révocable, expire à la date choisie, ne demande aucun compte au destinataire, et compte ses consultations.

Portefeuille clients

Tous les sites dont vous vous occupez, regroupés par client, avec ce qui demande votre attention en premier.

6 site(s) · 2 problème(s) grave(s) ouvert(s) · 0 en retard · 3 avec une couverture incomplète

Clients

Nom du client Ajouter un client

Client D  mo Renommer Retirer

  quipe

Propri  taire de l'espace : agence@exemple.com

colleague@agence.com Inviter

CO  QUIPIERS

Pas encore de co  quipier.

Marque des rapports

Affich  e en haut de chaque rapport client.

Nom de l'agence

Agence D  mo

Logo (PNG, JPEG ou SVG)

Choisir une image

Enregistrer

Clients

Client D  mo    traiter : 1

acquiscan.com 15/09/2026

probl  me(s) grave(s) ouvert(s) · dernier scan incomplet

11 Ouverts 2 Graves 0 En retard Approfondi, partiel

Client D  mo Probl  mes Scanner

Sans client    traiter : 3

clickup.com 09/09/2026

Rien d'urgent

0 Ouverts 0 Graves 0 En retard Approfondi, complet

aucun Probl  mes Scanner

france-telephone.com 09/09/2026

Rien d'urgent

0 Ouverts 0 Graves 0 En retard Approfondi, complet

aucun Probl  mes Scanner

gestionscolairepro.app 08/09/2026

dernier scan incomplet

0 Ouverts 0 Graves 0 En retard Approfondi, partiel

aucun Probl  mes Scanner

FIGURE 8.1 – Le portefeuille clients : chaque site avec sa note, ses probl  mes ouverts, ses probl  mes graves, ceux en retard, et l'  tat de sa couverture.

T  l  charger en PDF

Agence D  mo

Rapport d'  tat de s  curit   du site web

sohaibmokhliss.github.io

Pr  par   le 17/09/2026

B 88 / 100

0 CRITIQUE 0   LEV   1 MOYEN 4 FAIBLE

5 probl  me(s) ouvert(s), aucun n'est grave.

- Dernier scan le 17/09/2026 : note B, score 88/100.
- Certains contr  les n'ont pas abouti lors du dernier scan (Listes noires et malwares) ; la couverture est partielle.
- Le dernier scan n'a ex  cut   que des contr  les passifs ; les contr  les approfondis n  cessitent l'autorisation du propri  taire.
- Le rapport pr  c  dent (14/09/2026) ne couvrait pas les m  mes contr  les ; les scores ne sont pas compar  s.

Probl  mes ouverts, du plus grave au plus b  nin

GRAVIT��	PROBL��ME	CONTR��LE	OUVERT DEPUIS
MOYEN	Les pages peuvent ��tre int��gr��es dans des cadres sur d'autres sites (clickjacking)	En-t��tes de s��curit��	14/09/2026
FAIBLE	Les navigateurs peuvent deviner le type des fichiers (MIME sniffing)	En-t��tes de s��curit��	14/09/2026
FAIBLE	HSTS ne couvre pas les sous-domaines max-age=31556952	En-t��tes de s��curit��	14/09/2026
FAIBLE	Aucune Content Security Policy	En-t��tes de s��curit��	14/09/2026
FAIBLE	Aucune page de politique de confidentialit�� trouv��e	Pages de confiance	14/09/2026

Corrections v  rifi  es

FIGURE 8.2 – Le rapport client : r  sum   pour d  cideur, probl  mes ouverts, corrections v  rifi  es. Le bandeau de t  te re  oit le nom et le logo de l'agence lorsqu'ils sont configur  s.

Chapitre 9

Surveillance

Un scan complet chaque semaine, et un contrôle léger chaque jour sur ce qui change sans que personne ne touche au site : en-têtes, certificat, DNS et réputation.

Une alerte n'est envoyée que lorsque quelque chose d'important change : un nouveau constat grave, un problème de certificat ou de liste noire, une vraie baisse de score. Les corrections seules attendent le résumé hebdomadaire. Les destinataires sont choisis par site, et la même alerte peut partir vers Slack, Discord ou n'importe quel webhook JSON. Un site devenu injoignable déclenche une alerte, une seule, et non une par tentative.

Le contrôle léger ne compare que les contrôles qu'il a réellement exécutés : il ne peut donc pas déclarer corrigé un constat appartenant à un contrôle qu'il n'a pas lancé.

The screenshot displays the 'DevSecAudit' web application interface. At the top, there is a navigation bar with links: 'Comment ça marche', 'Contrôles', 'Tarifs', 'Mes scans', and 'Clients'. On the right, there are language selectors for 'EN' and 'FR', a 'Déconnexion' button, and a 'Nouveau scan' button. The main content area is titled 'Surveillance active - prochain scan complet le 21/10/2026'. It contains several sections: 1. 'Contrôle léger quotidien' (checked), with a description: 'Exécute chaque jour les contrôles passifs rapides ; alerte seulement sur un nouveau problème grave, un souci de certificat ou de liste noire, ou une vraie baisse de score.' 2. 'E-mail de résumé hebdomadaire' (checked), with a description: 'Le résumé du scan complet chaque semaine, même si rien n'a changé.' 3. 'Destinataires des alertes', with a text input field containing 'agence@exemple.com' and a note: 'Séparés par des virgules, 10 au maximum. Vide = le propriétaire de l'espace.' 4. 'URL Slack / Discord / webhook', with a text input field containing 'https://hooks.slack.com/services/...'. Below this is a note: 'Chaque alerte y est aussi envoyée en JSON (les webhooks entrants Slack et Discord fonctionnent tels quels)'. 5. Two buttons: 'Enregistrer' and 'Envoyer une alerte de test'. 6. 'Rapport client' section, with a description: 'Un rapport d'état à votre marque pour ce site : ce qui est ouvert, ce qui a été corrigé et vérifié, ce qui a changé. Partagez-le avec un lien qui expire.' It includes 'Aperçu' and 'Télécharger le PDF' buttons. 7. 'LIENS DE PARTAGE' section, with a 'Libellé (facultatif), ex. Rapport mensuel' input field, a '30 jours' dropdown, and a 'Créer un lien' button. Below this, there is a table of generated links: 'Rapport mensuel' (expires 14/10/2026, 1 view) and 'September report' (expires 14/10/2026, 2 views). Each link has 'Copier' and 'Révoquer' buttons. A small 'N' icon is visible in the bottom left corner.

FIGURE 9.1 – Réglages de surveillance par site : contrôle léger quotidien, résumé hebdomadaire, destinataires des alertes et webhook.

Chapitre 10

Sécurité de la plateforme elle-même

Un scanner est, par construction, un bon candidat au rôle de *deputy* confus : on lui demande d'aller chercher des adresses choisies par des inconnus.

10.1 Sortie réseau du scanner

Valider le domaine une fois au départ ne dit rien de l'endroit où pointe une redirection, une sous-ressource d'une page, ou une seconde résolution DNS. Toutes les requêtes sortantes passent donc par une règle unique qui refuse les adresses privées, de bouclage, de lien local et les adresses de méta-données des fournisseurs de cloud, ainsi que les schémas autres que HTTP et HTTPS et les identifiants placés dans l'URL. Les redirections ne sont plus suivies automatiquement : chaque saut est validé avant d'être récupéré. Le navigateur sans interface reçoit la même barrière sur chaque requête que la page tente, et le bac à sable de Chromium est actif par défaut.

La résolution DNS pouvant changer entre la vérification et la connexion, la documentation de déploiement exige en complément un filtrage de sortie au niveau du réseau.

10.2 Facturation

Le chemin de l'argent est délibérément ennuyeux : seuls les types d'événements documentés modifient quelque chose, le corps brut de la requête est vérifié par signature, les identifiants de livraison et de paiement sont suivis séparément pour qu'un même paiement livré deux fois n'accorde qu'un crédit, et le remboursement d'un audit déjà appliqué à un site met fin à l'accès qu'il avait payé au lieu de le laisser courir.

10.3 Données personnelles

L'adresse IP et l'empreinte de navigateur collectées à l'inscription servent uniquement à limiter les comptes gratuits en double. Elles sont réellement supprimées au bout de quatre-vingt-dix jours par une tâche planifiée, ce qui correspond à ce que promet la politique de confidentialité.

Chapitre 11

Licences et sources de données

Plusieurs sources de sécurité sont gratuites pour un usage non commercial uniquement. Le produit considère donc un déploiement comme commercial **sauf indication contraire** : un réglage oublié désactive une source restreinte, il ne l'active jamais.

Source ou outil	Position
Google Safe Browsing	Jamais interrogé en usage commercial ; remplacé par Google Web Risk, payant.
VirusTotal, WPScan, URLhaus	Intégrés mais désactivés tant qu'une licence n'est pas obtenue pour chacun.
Nuclei et ses modèles	MIT : usage commercial libre, mentions conservées.
Nmap	Usage hébergé autorisé avec mention visible et lien, présents sur une page de crédits publique.
Nikto	Le scanner est invoqué comme processus séparé ; les conditions propres à sa base de signatures restent à clarifier.
sslyze et nassl	AGPLv3, importés dans le backend : question ouverte, à trancher entre isolation, remplacement ou publication du code.
Valkey	BSD-3, maintenu ; retenu plutôt que Redis, dont les versions récentes changent de licence et dont la dernière version BSD porte une vulnérabilité critique non corrigée.

Les deux questions ouvertes sont documentées dans le dépôt plutôt que passées sous silence : c'est une information qu'un acheteur vérifiera.

Chapitre 12

Qualité et tests

12.1 Tests automatisés

Le projet compte **205 tests** automatisés, tous verts. Ils couvrent trois niveaux :

- les contrôles eux-mêmes, avec des réponses HTTP simulées : aucun test ne touche internet ;
- l'API : offres, autorisations, facturation, invitations, problèmes, rapports, partage ;
- les règles d'honnêteté, testées par la panne : page injoignable, sonde sans réponse, outil en erreur, scan périmé arrivant en retard, page illisible.

Cette dernière famille est la plus utile du projet. Tester qu'un scanner trouve quelque chose est facile ; tester qu'il refuse de conclure quand il n'a rien vu l'est moins, et c'est précisément là que se logent les erreurs qui coûtent la confiance d'un client.

12.2 Contrôles statiques et interface

Le code Python est vérifié et formaté par Ruff ; l'interface est vérifiée par ESLint et par le compilateur TypeScript, puis construite en mode production à chaque modification significative.

12.3 Revues successives

Le produit a fait l'objet de trois revues externes détaillées au cours du projet. Elles ont conduit, entre autres, à séparer l'autorisation du paiement, à cesser de présenter un contrôle en échec comme un contrôle réussi, à rendre la facturation idempotente et signée, à exiger l'acceptation explicite d'une invitation, à confiner la sortie réseau du scanner, et à traiter les licences des sources de données comme restrictives par défaut.

Chapitre 13

Déploiement et exploitation

Le déploiement tient dans un fichier Docker Compose : l'API, les workers, le planificateur, la base PostgreSQL, la file Valkey et un serveur Caddy qui obtient et renouvelle seul les certificats. Une sauvegarde quotidienne de la base est conservée quatorze jours. L'ensemble fonctionne sur un seul petit serveur.

Côté exploitation, une sonde périodique interroge chaque clé d'API et chaque quota ; les échecs déclenchent une alerte vers un webhook Slack ou Discord ; les contrôles ignorés pour une raison temporaire sont relancés ; et une tâche de ménage marque en échec les scans abandonnés par un worker disparu, afin qu'un client ne reste pas devant un indicateur qui tourne indéfiniment.

Chapitre 14

Modèle économique

Offre	Prix	Contenu
Gratuit	0 \$	3 sites, un scan chacun ; score, note, chaque constat expliqué ; contrôles approfondis sur les sites dont la propriété est vérifiée.
Audit détaillé	29 \$ une fois	Un site, 30 jours : correctif pas à pas pour chaque constat, prompt IA, rapport PDF, re-scans illimités.
Surveillance	49 \$ par mois	Tout l'audit détaillé sur tous les sites, scan complet hebdomadaire et contrôle léger quotidien jusqu'à 5 sites, alertes, espace client, rapports à la marque de l'agence.

Quarante-neuf dollars pour cinq sites surveillés représentent moins de dix dollars par site et par mois, à comparer aux scanners professionnels facturés de 39 à 190 \$ par mois pour cinq cibles et à la protection gérée facturée de 20 à 45 \$ par site. Les paiements et les reversements passent par Whop, qui agit comme marchand officiel et prend en charge la TVA et les devises.

DevSecAudit

Comment ça marche

Contrôles

Tarifs

Mes scans

Clients

EN

FR

Déconnexion

Nouveau scan

TARIFS

Des tarifs simples qui grandissent avec vous

Les 22 contrôles sur toutes les offres. Ne payez que pour le guide de correction complet, le prompt IA ou la surveillance continue.

Compte gratuit

3 sites, un scan chacun

0 \$

Commencer à scanner

✓ Scannez jusqu'à 3 sites web, une fois chacun

✓ Score de risque global et note en lettre

✓ Chaque constat expliqué en langage clair

✓ Contrôles approfondis et re-scans sur les sites que vous vérifiez

Le plus populaire

Rapport détaillé

Un site, 30 jours de re-scans

29 \$ paiement unique

Achetez-en un par site, quand vous en avez besoin.

Paiement pas encore configuré

✓ Tout le Gratuit, plus :

✓ Chaque constat avec ses correctifs pas à pas

✓ Contrôles approfondis sur ce site une fois vérifié ou votre autorisation confirmée

✓ Prompt IA de correction pour Claude / ChatGPT

✓ Rapport PDF

Surveillance

Pour les agences qui gèrent des sites clients

49 \$ / mois

Moins de 10 \$ par site et par mois. Résiliable à tout moment.

Votre offre actuelle

✓ Tout le Rapport détaillé, plus :

✓ Un scan complet chaque semaine et un contrôle léger chaque jour

✓ Une alerte seulement quand quelque chose d'important change, aux destinataires de votre choix

✓ Résumé hebdomadaire avec la tendance du score, ou rien si vous préférez

✓ Surveillance de 5 sites maximum,

FIGURE 14.1 – La page de tarifs.

Chapitre 15

Résultats, limites et perspectives

15.1 Ce qui fonctionne de bout en bout

Connexion, scan avec progression en direct, rapport, export PDF, suivi des problèmes avec re-test ciblé, correctifs guidés, espaces agence et rapports clients, surveillance hebdomadaire et quotidienne avec alertes par e-mail et webhook, vue d'exploitation, outil en ligne de commande. Le déploiement de production est scripté, avec HTTPS automatique et sauvegardes quotidiennes.

15.2 Limites assumées

- Le produit audite un site de l'extérieur. Une bonne note signifie que rien de visible n'est anormal, pas qu'il n'existe aucun problème.
- Il ne teste ni l'authentification, ni la logique métier, ni quoi que ce soit derrière une page de connexion, et ne prétend pas le faire.
- Un site protégé par un dispositif anti-robot agressif produit un rapport partiel, qui indique les contrôles n'ayant pas pu s'exécuter.
- Deux questions de licence restent ouvertes (chapitre 11).

15.3 Perspectives

Par ordre d'utilité décroissante :

1. une base de vulnérabilités JavaScript maintenue, à la place de la liste actuellement entretenue à la main ;
2. la priorisation par exploitation réelle : catalogue CISA KEV et probabilité EPSS attachés aux CVE reconnues, pour répondre à « que dois-je corriger en premier ? » ;
3. l'analyse passive d'OWASP ZAP, exécutée de façon isolée et strictement bornée ;
4. la surveillance de pages critiques choisies par le client : la page de contact répond-elle encore, la page de connexion s'affiche-t-elle, un script tiers est-il apparu après un déploiement ;
5. la séparation des scores de sécurité, de disponibilité, de performance et de couverture, pour qu'un chiffre unique ne masque plus la catégorie qui a bougé.

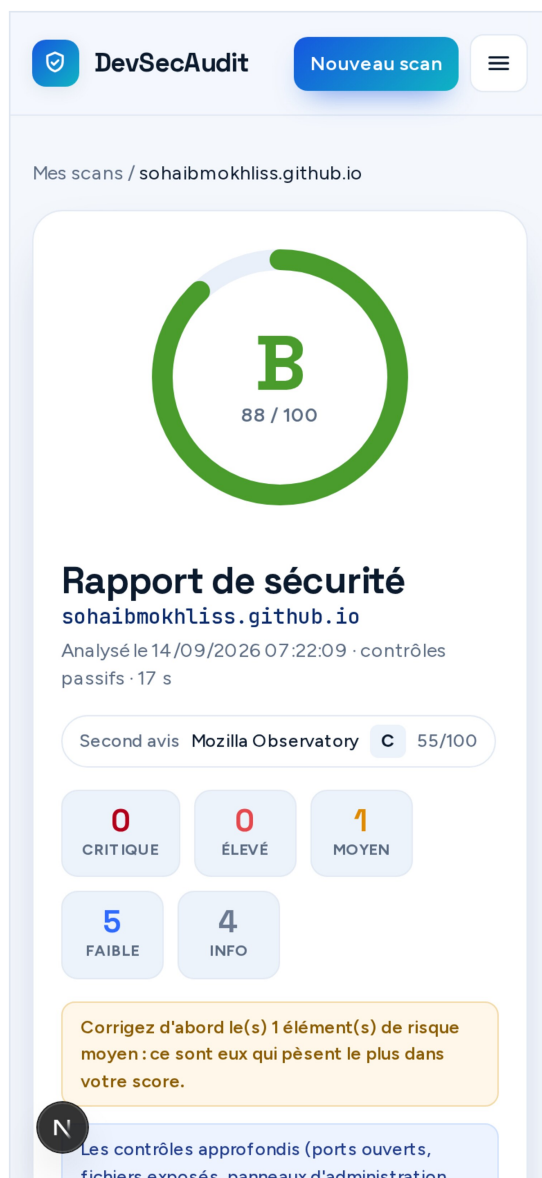


FIGURE 15.1 – L'interface est utilisable sur téléphone : le rapport complet en une colonne.

Chapitre 16

Conclusion

Les outils que ce projet exécute sont open source et libres d'accès. Ce que le produit apporte se situe au-dessus : la traduction en langage clair, le score étalonné, le correctif écrit pour la plateforme réellement utilisée, la preuve qu'une correction a bien eu lieu, et le modèle de compte, de propriété et de facturation qui rend l'ensemble vendable à des personnes qui ne sont pas ingénieurs.

S'il fallait ne retenir qu'une décision de conception, ce serait le refus de laisser une question sans réponse ressembler à une bonne nouvelle. C'est la partie du travail la plus difficile à réaliser, la plus facile à négliger, et la seule qui permette à un client de croire le mot *corrigé*.

Annexe A

Captures complémentaires



FIGURE A.1 – La page d'accueil.

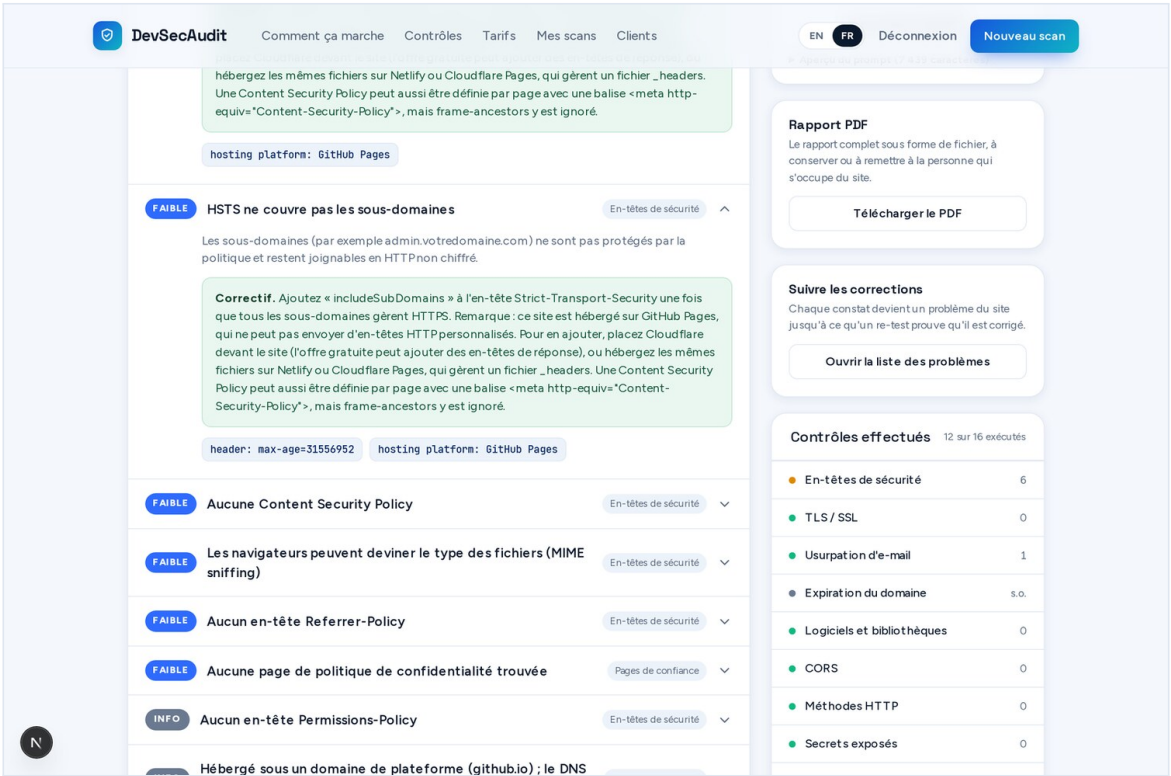


FIGURE A.2 – Les constats, du plus grave au plus bénin, avec le correctif de chacun.



FIGURE A.3 – Première page du rapport PDF, au format A4.

balise <meta http-equiv="Content-Security-Policy">, mais frame-ancestors y est ignoré.

Preuves: {"report_only":null,"hosting_platform":"GitHub Pages"}

4. [LOW] Les navigateurs peuvent deviner le type des fichiers (MIME sniffing) (contrôle : headers, id : headers.no_nosniff)

Ce que le scanner a vu: Sans X-Content-Type-Options, certains navigateurs traitent des fichiers téléversés ou mal étiquetés comme des scripts ou du HTML, ce qui peut mener à une injection de script.

Correctif suggéré par le scanner: Envoyez l'en-tête « X-Content-Type-Options: nosniff ».

Remarque : ce site est hébergé sur GitHub Pages, qui ne peut pas envoyer d'en-têtes HTTP personnalisés. Pour en ajouter, placez Cloudflare devant le site (l'offre gratuite peut ajouter des en-têtes de réponse), ou hébergez les mêmes fichiers sur Netlify ou Cloudflare Pages, qui gèrent un fichier _headers. Une Content Security Policy peut aussi être définie par page avec une balise <meta http-equiv="Content-Security-Policy">, mais frame-ancestors y est ignoré.

Preuves: {"hosting_platform":"GitHub Pages"}

5. [LOW] Aucun en-tête Referrer-Policy (contrôle : headers, id : headers.no_referrer_policy)

Ce que le scanner a vu: Quand des visiteurs cliquent un lien vers un autre site, l'URL complète d'où ils viennent (qui peut contenir des jetons ou des chemins privés) est envoyée à ce site.

Correctif suggéré par le scanner: Envoyez « Referrer-Policy: strict-origin-when-cross-origin ».

Remarque : ce site est hébergé sur GitHub Pages, qui ne peut pas envoyer d'en-têtes HTTP personnalisés. Pour en ajouter, placez Cloudflare devant le site (l'offre gratuite peut ajouter des en-têtes de réponse), ou hébergez les mêmes fichiers sur Netlify ou Cloudflare Pages, qui gèrent un fichier _headers. Une Content Security Policy peut aussi être définie par page avec une balise <meta http-equiv="Content-Security-Policy">, mais frame-ancestors y est ignoré.

Preuves: {"hosting_platform":"GitHub Pages"}

6. [LOW] Aucune page de politique de confidentialité trouvée (contrôle : trust_pages, id : trust_pages.privacy_policy_missing)

Ce que le scanner a vu: La plupart des pays exigent une politique de confidentialité dès que vous collectez des données de visiteurs (formulaire de contact, statistiques, cookies). C'est aussi la première chose que cherchent les clients prudents.

Correctif suggéré par le scanner: Publiez une page de politique de confidentialité et liez-la depuis le pied de page. Les générateurs gratuits couvrent l'essentiel ; faites-la relire par un juriste si vous vendez en ligne.

INFORMATIF (4) : Aucun en-tête Permissions-Policy; Hébergé sous un domaine de plateforme (github.io) ; le DNS est géré par la plateforme; Aucune page de conditions ou de mentions légales trouvée; Aucune page de contact trouvée

CONSIGNES

1. Traite les constats dans l'ordre indiqué.
2. Pour chacun, donne : (a) une phrase simple expliquant le risque, (b) le changement exact pour la pile détectée (un extrait de configuration, un enregistrement DNS, ou les clics précis dans le panneau de contrôle nommé), (c) une ligne pour vérifier que cela a fonctionné.
3. Si un correctif dépend de quelque chose que tu ignores (quel panneau d'hébergement, quel fournisseur DNS, ou si une page est censée être publique), pose une courte question au lieu de deviner.
4. Regroupe les correctifs qui relèvent d'un même changement (par exemple plusieurs en-têtes HTTP définis au même endroit).
5. Signale tout ce qui pourrait casser le site si c'est mal fait, et explique comment revenir en arrière.
6. Termine par une liste de contrôle classée par impact rapporté à l'effort, en indiquant ce que le propriétaire peut faire seul et ce qui nécessite un développeur.

Réponds en français.

Préparé par Agence Démo avec DevSecAudit (<http://localhost:3000>). Les constats décrivent ce qui était observable de l'extérieur au moment du scan et ne garantissent pas l'absence d'autres problèmes.

FIGURE A.4 – Le prompt de correction, inclus dans le PDF.

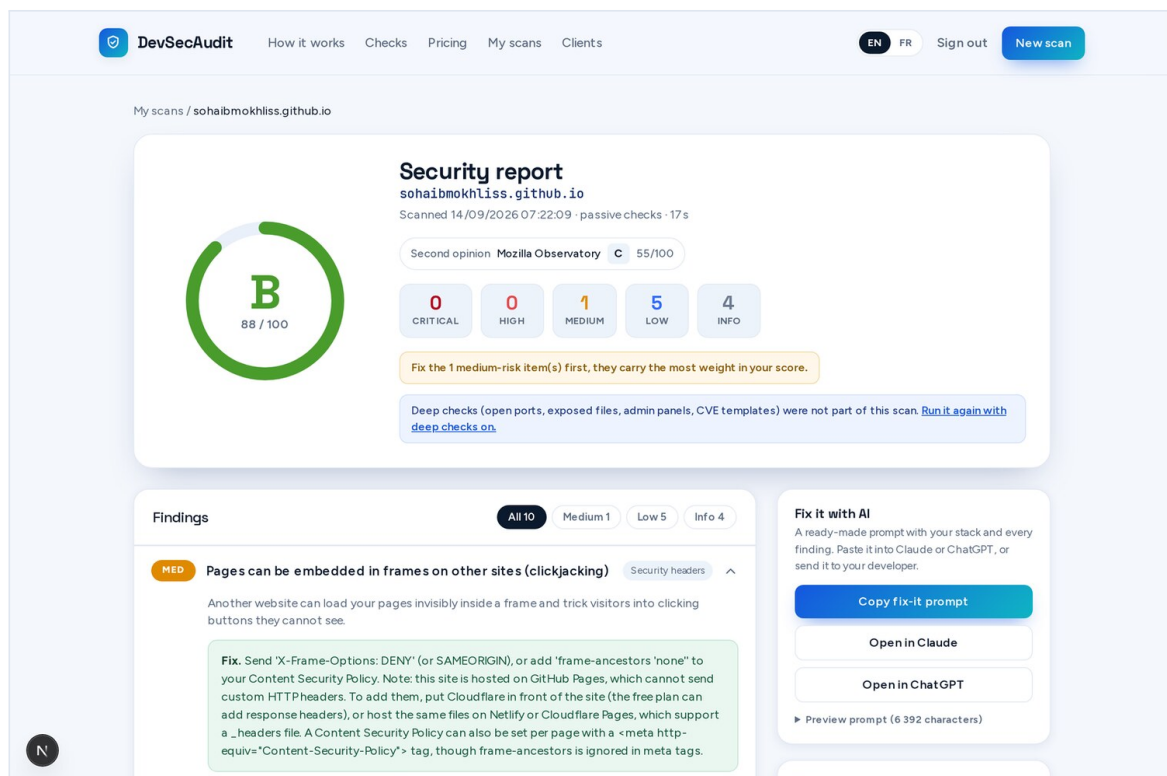


FIGURE A.5 – Le même rapport en anglais : l'interface, les constats, les correctifs, le PDF et les e-mails sont bilingues.